
Re: 10 8 2025 - Phase 1 Development Details

From Pouya Barrach-Yousefi <pouya@cervais.com>

Date Thu 10/9/2025 11:25 PM

To Haroon Ahmad Awan <mrharoonawan@gmail.com>

Cc James Austin <jaustin@cervais.com>

Dear Haroon,

Hope you're well.

Thank you for the SOW.

I would like to request the following and confirmation from you:

1. Use our cervais org github
 - a. Provide me your dev team's email addresses
2. Use typical branch protect ruleset:
 - a. main branch: Protected, requires PR approval
 - b. Commit signing: Required (GPG)
 - c. Status checks: All CI/CD checks must pass
3. Use GitHub Projects hosted in Cervais for our Project Management Platform
 - a. All work must be tracked as GitHub Issues
 - b. Code-to-Ticket Traceability - All commits must reference an issue number
4. Include me in sprint ceremonies
 - a. daily stand-up
 - b. Sprint review
 - c. Demo (weekly? End of sprint?)
5. Track all architectural, tactical, and procedural decisions in a "decision-log" markdown document.
 - a. Strategic decisions with long-term impact on system structure
 - i. Programming language and framework choices
 - ii. Communication protocols and patterns
 - iii. Cryptographic algorithm selections
 - iv. Data storage and persistence strategies
 - v. Security model and trust boundaries
 - vi. System decomposition and service boundaries
 - vii. Integration patterns and APIs
 - viii. Deferral of features to future phases

I noticed the following gaps in what is quite important to me, CI/CD:

1. Pipeline Architecture & Stages - Not Defined

The SOW doesn't specify:

- **Build stages:** Compilation, dependency caching, multi-arch builds
- **Test stages:** Unit tests (with coverage thresholds), integration tests, security tests
- **Quality gates:** What causes a build to fail?
- **Deployment stages:** Artifact publishing, package signing

2. Testing Integration - Severely Underspecified

- **No mention of automated test execution** in the pipeline
- **No code coverage requirements** (though the improvement roadmap mentions 80%)
- **No test framework specification** (e.g., cargo test,)
- **Sprint 4 mentions creating tests**, but Sprint 1 should establish the testing infrastructure

3. Code Quality & Security Scanning - Missing

For Rust security-critical code, you need:

Should be specified in SOW:

- cargo clippy (linting)
- cargo fmt (formatting checks)
- cargo audit (dependency vulnerabilities)
- cargo deny (license/security policy enforcement)
- SAST tools (e.g., Semgrep, CodeQL)

4. Artifact Management - Not Addressed

- Where are .deb/.rpm packages stored?
- How are they versioned and signed?
- Container registry for any Docker images?
- Binary reproducibility requirements?

5. Deployment Automation - Missing

The SOW mentions creating packages but not:

- Automated deployment to test environment
- Deployment verification tests
- Rollback procedures

6. Development Workflow - Underspecified

- **No Git branching strategy** (trunk-based? GitFlow?)
- **No PR/review requirements**
- **No commit signing requirements** (critical for security)

Can you please update the deliverables to Include:

1. Working CI/CD pipeline with automated:

- Build verification
- Unit test execution
- Code quality checks
- Security scanning
- Artifact generation

2. CI/CD_Pipeline_Documentation.md:

- Pipeline architecture diagram
- Quality gate definitions
- Workflow procedures
- Troubleshooting guide

Let me know if I can clarify anything.